exec.txt
TXT 52.98KB

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Análise Passo a Passo do Arquivo `exec.txt`

1. Identificação do Arquivo

O arquivo `exec.txt` **não é um arquivo de texto comum**. Trata-se, na verdade, de um **bytecode Python compilado (`.pyc`)** — provavelmente renomeado para `.txt`. Os primeiros bytes (`L��jA` e o cabeçalho `\x00\x00\x00\x00`) são típicos de um arquivo `.pyc` do Python 3.x.

Isso já é um **forte indicador de ofuscação/evasão**: o autor esconde o código-fonte compilado sob uma extensão inofensiva.

2. Extração do Conteúdo

Ao descompilar o bytecode, emergem os nomes das classes e funções:

- `WindowsAPI`
- `AntiAnalysis` (check_vm, check_debugger, check_sandbox, evade)
- `ProcessHollowing`
- `FileEncryptor`
- `MBRLocker`
- `ShadowCopyDeleter`
- `Persistence`
- `EmailSender`
- `RansomNote`
- `LiushenRansomware`

A simples presença desses nomes já é **altamente suspeita**.

3. Análise de Componentes

3.1 `WindowsAPI`

Wrapper para chamadas à API do Windows (`kernel32` , `ntdll` , `user32` , `shell32`), incluindo verificação de privilégios de administrador (`IsUserAnAdmin`) e enumeração de drives (`GetLogicalDriveStringsW`). Comportamento típico de malware que precisa de privilégios elevados.

3.2 `AntiAnalysis`

- `check_vm` : detecta VirtualBox, VMware, QEMU, Virtual PC, Hyper-V via WMI e MAC addresses (`00:0c:29` , `00:50:56` , `08:00:27`).
- `check_debugger` : usa `IsDebuggerPresent` e timing attack (`perf_counter`).
- `check_sandbox` : verifica uptime baixo, RAM baixa, poucos núcleos de CPU, disco pequeno.
- `evade` : se detecta VM/debugger/sandbox, **corrompe memória deliberadamente** (`memset` em ponteiro `c_void_p`) e chama `sys.exit` .

Isso é **anti-análise clássica de malware**.

3.3 `ProcessHollowing`

Implementa **Process Hollowing** completo: cria processo suspenso (`svchost.exe`), desmapeia imagem, aloca memória (`VirtualAllocEx`), escreve payload (`WriteProcessMemory`), ajusta contexto (`SetThreadContext`), e retoma execução (`ResumeThread`). Técnica clássica de **injeção de código malicioso**.

3.4 `FileEncryptor`

- Usa **AES** (`Crypto.Cipher.AES`) em modo CBC com `get_random_bytes` .
- Criptografa arquivos com extensões típicas de vítima (`.doc` , `.xls` , `.pdf` , `.jpg` , `.zip` , `.sql` , `.key` , `.vmdk` , etc.).
- Usa `threading` e `Lock` para paralelizar.
- `_secure_delete` : sobrescreve arquivos originais com `urandom` antes de deletar (anti-forense).

Isso é **ransomware funcional**.

3.5 `MBRLocker`

Sobrescreve o **Master Boot Record** (`\\.\PhysicalDrive0`) com uma mensagem de resgate, incluindo:

- Valor em USD
- Endereço Ethereum (`0x742d35Cc6634C0532925a3b844Bc454e4438f44e`)
- Instruções de pagamento

Isso é **ransomware de MBR (bootkit)**.

3.6 `ShadowCopyDeleter`

Executa comandos para destruir backups:

- `vssadmin delete shadows /all /quiet`
- `wmic shadowcopy delete`
- `diskshadow.exe delete shadows all`
- `bcdedit /set {default} recoveryenabled No`

Isso é **anti-recuperação clássica de ransomware**.

3.7 `Persistence`

Instala persistência via:

- Registro (`Run` / `RunOnce`)
- Pasta Startup
- Task Scheduler (`schtasks`)
- Serviço (`sc create`)

Isso é **persistência de malware**.

3.8 `EmailSender`

Envia relatórios para C2 (`http://your-c2-server.com/api`), coleta IP real, salva chaves localmente como fallback. Comunicação com **servidor de comando e controle (C2)**.

3.9 `RansomNote`

Cria notas de resgate em Desktop, Documents, Downloads e `README_LIUSHEN.txt`.

3.10 `LiushenRansomware`

Classe principal que:

- Gera **Victim ID** único
- Mata processos (Outlook, Excel, Word, SQL Server, MySQL, PostgreSQL, Oracle, backup, VSS, Task Manager, Process Explorer, Wireshark)
- Desativa Windows Defender, firewall, Windows Update, UAC
- Executa todos os módulos acima em sequência

4. Evidências Adicionais

- **Strings explícitas**: `LIUSHEN RANSOMWARE`, `YOUR FILES ARE ENCRYPTED`, `Pay ... USD to Ethereum address`, `DO NOT ATTEMPT TO REPAIR OR YOUR DATA WILL BE LOST FOREVER!`
- **Endereço Ethereum** hardcoded para receber resgate.
- **C2 server**: `http://your-c2-server.com/api`
- **Ofuscação**: arquivo `.pyc` renomeado para `.txt`; nomes de classes em inglês mas comentários em indonésio (`Wrapper untuk Windows API calls`, `Deteksi lingkungan virtual`, `Enkripsi file`), sugerindo autor indonésio.
- **Verificação de dependências**: instala `pycryptodome` e `pywin32` silenciosamente via `pip --quiet`.

5. Veredito

Este arquivo é MALWARE — especificamente um ransomware completo e funcional.

Ele combina, em um único artefato:

Categoria	Componente
Anti-análise	`AntiAnalysis` (VM, debugger, sandbox, evade)
Injeção de código	`ProcessHollowing`

Categoria	Componente
Criptografia de arquivos	`FileEncryptor` (AES-256 CBC)
Destruição de MBR	`MBRLocker`
Destruição de backups	`ShadowCopyDeleter`
Persistência	`Persistence` (4 métodos)
C2 / exfiltração	`EmailSender`
Nota de resgate	`RansomNote`
Orquestração	`LiushenRansomware`

Classificação final: MALWARE — Ransomware (Trojan.Ransom.Liushen / Ransomware.Liushen)

Recomendações imediatas:

1. **NÃO executar** o arquivo em nenhuma máquina.
2. Isolar o arquivo em ambiente air-gapped ou sandbox dedicado.
3. Submeter o hash a serviços como VirusTotal, Hybrid Analysis, Any.Run.
4. Bloquear o endereço Ethereum e o domínio `your-c2-server.com` em gateways de rede.
5. Verificar se há indicadores de comprometimento (IOCs) nos endpoints da organização.

Qual é a categoria principal deste malware?

Categoria Principal do Malware

A categoria principal é **RANSOMWARE**.

Justificativa

Embora o arquivo combine múltiplas técnicas (anti-análise, process hollowing, persistência, C2), o **propósito central** e a **cadeia de execução principal** são claramente de ransomware:

Evidências que definem a categoria principal:

Elemento	Função no Ransomware
`FileEncryptor`	Criptografa arquivos da vítima com AES-256 (CBC) — **operação central de ransomware**
`MBRLocker`	Bloqueia o boot sobrescrevendo o MBR — **técnica clássica de ransomware**
`RansomNote`	Cria notas de resgate em Desktop/Documents/Downloads — **extorsão**
`ShadowCopyDeleter`	Destrói backups (`vssadmin` , `wmic` , `diskshadow` , `bcdedit`) — **impede recuperação**
Endereço Ethereum hardcoded	Recebimento de pagamento de resgate
String `LIUSHEN RANSOMWARE`	Nome auto-declarado do malware
`_secure_delete`	Sobrescreve arquivos originais com `urandom` (anti-forense)

Por que não outras categorias como principal?

- **Não é apenas Trojan**: embora use process hollowing (técnica de trojan), isso serve para executar o ransomware.
- **Não é apenas Bootkit**: o MBR locker é um **componente** do ransomware, não o objetivo final.
- **Não é apenas Infostealer**: o `EmailSender` envia relatórios ao C2, mas não é o propósito central.
- **Não é apenas Worm**: não há evidência de propagação autônoma em rede.

Classificação taxonômica

```text
Tipo:        Ransomware
Subtipo:     Ransomware com MBR Locker (Bootkit Ransomware)
Família:     Liushen
```

```
Variante:    PoC (Proof of Concept) — conforme string "Liushen Ransomware PoC"
Plataforma:  Windows (x64)
Linguagem:   Python (compilado para .pyc)
```

Resumo em uma frase: É um **ransomware** que criptografa arquivos, destrói backups, bloqueia o MBR e exige pagamento em Ethereum — todas as demais funcionalidades (anti-VM, process hollowing, persistência, C2) são **auxiliares** para garantir o sucesso da extorsão.